

MATERIAL EDUCATIVO

RA1: Planes de Prevención y Concienciación en Ciberseguridad

PLANTILLAS Y RECURSOS

Módulo: Incidentes de Ciberseguridad

Curso: Especialización en Ciberseguridad en Entornos de las TI

Centro: CIFP César Manrique

Curso Académico: 2024-2025

Este documento contiene plantillas editables para el desarrollo de planes de prevención y concienciación en ciberseguridad, normativas de protección del puesto de trabajo, planes anuales de formación e informes de auditoría.

Información del Módulo

Campo	Descripción
Denominación	Incidentes de Ciberseguridad
Código	991NTA_CIBERTIC
Familia Profesional	Informática y Comunicaciones
Nivel	Formación Profesional de Grado Superior
Duración	145 horas (4 horas semanales)
Curso	2024-2025

Resultados de Aprendizaje (RA)

RA1. Desarrolla planes de prevención y concienciación en ciberseguridad, estableciendo normas y medidas de protección (15%).

Este resultado de aprendizaje se enfoca en la capacidad del estudiante para:

- Definir los principios generales de la organización en materia de ciberseguridad
- Establecer una normativa de protección del puesto de trabajo
- Definir un plan de concienciación dirigido a los empleados
- Desarrollar material necesario para acciones de concienciación
- Realizar auditorías para verificar el cumplimiento del plan

Sobre este Documento

Este documento recopila cuatro plantillas profesionales diseñadas para facilitar el desarrollo de los entregables asociados al RA1:

- 1. Documento de Principios de Ciberseguridad:** Plantilla para definir los principios fundamentales que guiarán las políticas de seguridad de la organización.
- 2. Normativa de Protección del Puesto de Trabajo:** Marco completo para establecer requisitos mínimos de seguridad en los puestos de trabajo.
- 3. Plan Anual de Concienciación:** Estructura detallada para planificar y ejecutar programas de formación y concienciación durante un año completo.

4. Informe de Auditoría: Plantilla para documentar los resultados de auditorías de cumplimiento de planes de prevención y concienciación.

Todas las plantillas incluyen secciones editables y están diseñadas siguiendo mejores prácticas del sector y estándares internacionales (ISO 27001, ENS, NIST).

Índice de Contenidos

1.	Información del Módulo	2
2.	Plantilla 1: Documento de Principios de Ciberseguridad	4
	2.1. Introducción y Compromiso de la Dirección	4
	2.2. Alcance y Aplicabilidad	5
	2.3. Principios Fundamentales	5
	2.4. Responsabilidades	6
	2.5. Cumplimiento y Sanciones	7
3.	Plantilla 2: Normativa de Protección del Puesto de Trabajo	8
	3.1. Seguridad Física del Puesto	9
	3.2. Seguridad Lógica	10
	3.3. Uso Aceptable de Recursos	12
	3.4. Teletrabajo y Movilidad	14
	3.5. Gestión de Incidentes	16
4.	Plantilla 3: Plan Anual de Concienciación	17
	4.1. Análisis de Situación	18
	4.2. Objetivos y KPIs	19
	4.3. Público Objetivo	20
	4.4. Metodologías y Actividades	21
	4.5. Calendario	23
	4.6. Recursos y Presupuesto	25
5.	Plantilla 4: Informe de Auditoría	27
	5.1. Alcance y Metodología	28
	5.2. Hallazgos Detallados	29
	5.3. Evaluación de Madurez	31

5.4. Recomendaciones y Plan de Acción	32
6. Referencias y Recursos	34

PLANTILLA 1: DOCUMENTO DE PRINCIPIOS DE CIBERSEGURIDAD

[LOGO EMPRESA]

PRINCIPIOS GENERALES DE CIBERSEGURIDAD

[Nombre de la Organización]

Versión: 1.0

Fecha: DD/MM/AAAA

Clasificación: [Interna/Confidencial]

Aprobado por: [Nombre + Cargo]

1. INTRODUCCIÓN Y COMPROMISO DE LA DIRECCIÓN

[Declaración del CEO/Dirección sobre importancia de la ciberseguridad]

La Dirección de [ORGANIZACIÓN] reconoce que la información y los sistemas tecnológicos son activos críticos para el negocio. La protección de estos activos es fundamental para mantener la confianza de nuestros clientes, socios y empleados, así como para garantizar la continuidad de nuestras operaciones.

Este documento establece los principios fundamentales que guiarán todas las decisiones y acciones relacionadas con la ciberseguridad en nuestra organización.

2. ALCANCE Y APLICABILIDAD

Este documento aplica a:

- ■ Todos los empleados
- ■ Contratistas y proveedores
- ■ Todos los sistemas de información
- ■ Todas las ubicaciones de la organización

3. PRINCIPIOS FUNDAMENTALES

3.1 PRINCIPIO 1: Seguridad por Diseño

Descripción: La seguridad debe ser considerada desde el inicio de cualquier proyecto, sistema o proceso, no como un añadido posterior.

Implicaciones: Todos los proyectos deben incluir un análisis de riesgos de seguridad en su fase de diseño.

Responsables: Directores de proyecto, arquitectos de sistemas

3.2 PRINCIPIO 2: Defensa en Profundidad

Descripción: Se implementarán múltiples capas de seguridad para proteger los activos críticos.

Implicaciones: No se debe confiar en una única medida de seguridad. Aplicar controles complementarios.

Responsables: Equipo de Seguridad, Responsables de TI

3.3 PRINCIPIO 3: Privilegio Mínimo

Descripción: Los usuarios y sistemas tendrán únicamente los permisos necesarios para realizar sus funciones.

Implicaciones: Revisión periódica de permisos y accesos. Política de acceso restrictiva por defecto.

Responsables: Administradores de sistemas, Gestores de identidad

3.4 PRINCIPIO 4: Segregación de Funciones

Descripción: Las funciones críticas serán divididas entre diferentes personas para prevenir fraudes y errores.

Implicaciones: Diseño de procesos que requieran múltiples aprobaciones para acciones críticas.

Responsables: Directores de departamento, Auditoría interna

3.5 PRINCIPIO 5: Transparencia y Trazabilidad

Descripción: Todas las acciones en sistemas críticos serán registradas y auditables.

Implicaciones: Implementación de sistemas de logging y monitorización. Conservación de registros.

Responsables: Equipo de Seguridad, Compliance

4. RESPONSABILIDADES

4.1 Dirección / Alta Dirección

- Aprobar y comunicar las políticas de ciberseguridad
- Asignar recursos adecuados para la seguridad
- Liderar con el ejemplo en materia de seguridad
- Revisar periódicamente el estado de la ciberseguridad

4.2 CISO / Responsable de Seguridad

- Desarrollar y mantener las políticas de seguridad
- Coordinar las actividades de seguridad en la organización
- Gestionar los incidentes de seguridad
- Reportar a la Dirección sobre el estado de la seguridad
- Coordinar auditorías y evaluaciones de seguridad

4.3 Jefes de Departamento / Managers

- Asegurar que su equipo conoce y cumple las políticas
- Identificar y reportar riesgos de seguridad en su área
- Participar en la gestión de incidentes que afecten a su departamento
- Facilitar la formación en seguridad de su equipo

4.4 Empleados

- Conocer y cumplir todas las políticas de seguridad
- Proteger sus credenciales y dispositivos asignados
- Reportar inmediatamente cualquier incidente o sospecha de seguridad
- Participar en las actividades de formación
- Aplicar el sentido común y la precaución en sus actividades diarias

4.5 Proveedores y Terceros

- Cumplir con las políticas de seguridad de la organización
- Proteger la información confidencial de la organización
- Notificar cualquier incidente que afecte a la organización
- Permitir auditorías de seguridad cuando sea requerido

5. CUMPLIMIENTO Y SANCIONES

El incumplimiento de estos principios puede resultar en medidas disciplinarias que pueden incluir desde amonestaciones verbales hasta la terminación del contrato laboral, dependiendo de la gravedad y reincidencia del incumplimiento.

Además de las sanciones internas, el incumplimiento de normativas legales aplicables puede resultar en responsabilidades legales y penales para los individuos y la organización.

6. REVISIÓN Y ACTUALIZACIÓN

Este documento será revisado anualmente o cuando cambios significativos en el entorno, la tecnología o la normativa lo requieran.

Próxima revisión: [Fecha]

7. REFERENCIAS

- ISO/IEC 27001:2022 - Sistemas de gestión de seguridad de la información
- Esquema Nacional de Seguridad (ENS) - España
- Reglamento General de Protección de Datos (RGPD)
- NIST Cybersecurity Framework
- [Otras referencias aplicables a su organización]

REGISTRO DE VERSIONES

Versión	Fecha	Autor	Cambios
1.0	DD/MM/AA	[Nombre]	Creación inicial

APROBACIONES

Preparado por: _____ **Fecha:** _____
[Nombre], [Cargo]

Revisado por: _____ **Fecha:** _____
[Nombre], [Cargo]

Aprobado por: _____ **Fecha:** _____
[Nombre], [Cargo - Dirección]

PLANTILLA 2: NORMATIVA DE PROTECCIÓN DEL PUESTO DE TRABAJO

[LOGO EMPRESA]

NORMATIVA DE PROTECCIÓN DEL PUESTO DE TRABAJO

[Nombre de la Organización]

Código: POL-SEC-002

Versión: 1.0

Fecha: DD/MM/AAAA

Propietario: CISO / Responsable de Seguridad

ÍNDICE

- 1. Objeto y Alcance
- 2. Definiciones
- 3. Responsabilidades
- 4. Seguridad Física del Puesto
- 5. Seguridad Lógica
- 6. Uso Aceptable de Recursos
- 7. Teletrabajo y Movilidad
- 8. Incidentes de Seguridad
- 9. Sanciones
- 10. Revisión

1. OBJETO Y ALCANCE

1.1 Objeto

Esta normativa establece los requisitos mínimos de seguridad que deben cumplir todos los puestos de trabajo para proteger la información y los sistemas de la organización frente a amenazas internas y externas.

1.2 Alcance

- ■ Puestos de trabajo en oficina

- ■ Puestos de teletrabajo
- ■ Dispositivos móviles corporativos
- ■ Todos los empleados, contratistas y personal temporal

2. DEFINICIONES

Puesto de trabajo: Espacio físico y conjunto de recursos tecnológicos asignados a un empleado.

Información sensible: Datos cuya divulgación no autorizada podría causar daño a la organización.

Dispositivo corporativo: Cualquier equipo propiedad de la organización.

Dispositivo personal (BYOD): Equipo propiedad del empleado usado para fines laborales.

3. RESPONSABILIDADES

Empleados: Cumplir con todas las medidas establecidas en esta normativa.

Managers: Asegurar que su equipo conoce y cumple la normativa.

IT/Seguridad: Implementar controles técnicos y auditar el cumplimiento.

RRHH: Asegurar que todos los empleados reciben formación en esta normativa.

4. SEGURIDAD FÍSICA DEL PUESTO

4.1 Política de Escritorio Limpio (Clean Desk)

OBLIGATORIO:

- ✓ No dejar documentos confidenciales sobre el escritorio al finalizar la jornada
- ✓ Guardar documentos sensibles en armarios con cerradura
- ✓ Bloquear la pantalla al ausentarse (Win+L / Ctrl+Alt+Supr)
- ✓ No dejar contraseñas escritas visibles
- ✓ Destruir documentos confidenciales en destructora (nivel P-4 mínimo)

PROHIBIDO:

- ✗ Dejar dispositivos USB, tokens o tarjetas visibles
- ✗ Documentos confidenciales en papeleras comunes

4.2 Control de Acceso Físico

- Las áreas de trabajo deben estar protegidas con control de acceso
- No permitir el acceso a personas no autorizadas (tailgating)
- Las tarjetas de acceso son personales e intransferibles
- Reportar tarjetas perdidas inmediatamente

4.3 Visitas y Personal Externo

- Las visitas deben estar siempre acompañadas
- No permitir que las visitas accedan a sistemas o vean información confidencial
- Las visitas deben llevar identificación visible

5. SEGURIDAD LÓGICA

5.1 Gestión de Contraseñas

REQUISITOS OBLIGATORIOS:

- ✓ Longitud mínima: 12 caracteres
- ✓ Complejidad: Mayúsculas + minúsculas + números + símbolos
- ✓ Cambio cada: [90 días para usuarios estándar, 60 para privilegiados]
- ✓ No reutilizar las últimas 5 contraseñas
- ✓ No compartir contraseñas NUNCA
- ✓ Usar gestor de contraseñas corporativo: [Nombre herramienta]

EJEMPLOS:

- ✓ Correcto: "MiP€rr0T0by!2024"
- ✗ Incorrecto: "123456", "password", "nombre123"

5.2 Autenticación Multifactor (MFA)

- ✓ OBLIGATORIO para: [servicios críticos: correo, VPN, sistemas financieros]
- ✓ Métodos autorizados: [App corporativa, SMS, token físico]

5.3 Bloqueo Automático de Sesión

- ✓ Tiempo máximo de inactividad: 5 minutos
- ✓ Requiere contraseña para desbloquear
- ✓ NUNCA deshabilitar esta función

5.4 Cifrado de Datos

- ✓ Cifrado de disco completo obligatorio (BitLocker/FileVault)
- ✓ Cifrado de dispositivos USB con información sensible
- ✓ Usar herramientas corporativas de cifrado: [Nombre]

5.5 Antivirus y Protección

- ✓ Antivirus corporativo siempre activo
- ✓ No desinstalar ni deshabilitar
- ✓ Actualizaciones automáticas activadas
- ✓ Análisis completo semanal automático

5.6 Actualizaciones del Sistema

- ✓ Instalar actualizaciones críticas en < 48h
- ✓ Actualizaciones automáticas activadas
- ✓ No posponer indefinidamente

6. USO ACEPTABLE DE RECURSOS

6.1 Uso de Internet

PERMITIDO:

- ✓ Uso profesional relacionado con el trabajo
- ✓ Uso personal moderado y razonable (pausas)

NO PERMITIDO:

- ✗ Descarga de contenido ilegal
- ✗ Acceso a páginas de contenido inapropiado
- ✗ Descarga de software no autorizado
- ✗ Streaming de vídeo/audio extensivo (congestiona red)

6.2 Uso de Correo Electrónico

OBLIGATORIO:

- ✓ Verificar remitente antes de abrir adjuntos
- ✓ Reportar emails sospechosos a: [email-seguridad@empresa.com]
- ✓ No responder a emails de phishing
- ✓ Usar cifrado para información sensible

PROHIBIDO:

- ✗ Enviar información confidencial a correos personales
- ✗ Abrir adjuntos de remitentes desconocidos
- ✗ Hacer clic en enlaces sospechosos

6.3 Redes Sociales

- ✓ Uso personal fuera de horario laboral
- ✗ No publicar información corporativa confidencial
- ✗ No hablar en nombre de la empresa sin autorización

6.4 Dispositivos Personales (BYOD)

[Indicar si están permitidos y bajo qué condiciones]

Si está permitido BYOD:

- Registro del dispositivo en MDM corporativo
- Cumplimiento de requisitos mínimos de seguridad
- Separación de datos personales y corporativos
- Derecho de la organización a borrar datos corporativos remotamente

6.5 Almacenamiento en la Nube

- ✓ Servicios autorizados: [OneDrive/Google Drive corporativo]
- ✗ Servicios NO autorizados: Dropbox personal, WeTransfer, etc.

7. TELETRABAJO Y MOVILIDAD

7.1 Requisitos para Teletrabajo

OBLIGATORIO:

- ✓ Uso de VPN corporativa para cualquier acceso
- ✓ Red WiFi doméstica protegida (WPA2/WPA3 mínimo)
- ✓ Espacio de trabajo privado (no cafeterías con información sensible)
- ✓ Portátil corporativo (no PC personal)
- ✓ Mismo nivel de seguridad que en oficina

PROHIBIDO:

- ✗ Acceso desde redes WiFi públicas sin VPN
- ✗ Compartir pantalla en videollamadas con información sensible visible detrás
- ✗ Permitir uso del equipo a familiares

7.2 Dispositivos Móviles

- ✓ PIN/contraseña obligatorio
- ✓ Cifrado activado
- ✓ Actualización sistema operativo
- ✓ No hacer jailbreak/root
- ✓ MDM corporativo instalado

7.3 Pérdida o Robo de Dispositivos

■ Reportar INMEDIATAMENTE a: [teléfono/email urgencias]

- Máximo 2 horas desde conocimiento del incidente

El equipo de TI procederá a:

- Bloqueo remoto del dispositivo
- Cambio de contraseñas
- Borrado remoto de datos si es necesario
- Denuncia ante autoridades

8. INCIDENTES DE SEGURIDAD

8.1 Tipos de Incidentes a Reportar

- Email de phishing recibido
- Malware detectado
- Pérdida/robo de dispositivo
- Acceso no autorizado sospechado
- Vulneración de datos
- Cualquier anomalía de seguridad

8.2 Cómo Reportar

- **Email:** seguridad@empresa.com
- **Teléfono:** [número]
- **Portal:** [URL]
- **Tiempo máximo:** 2 horas desde detección

9. SANCIONES

El incumplimiento de esta normativa puede resultar en:

- **Apercibimiento verbal** (1ª vez, incumplimiento leve)
- **Apercibimiento escrito** (reincidencia)
- **Suspensión de empleo y sueldo** (incumplimientos graves)
- **Despido disciplinario** (incumplimientos muy graves o reiterados)

Además de las responsabilidades legales que pudieran derivarse

10. REVISIÓN Y EXCEPCIONES

10.1 Revisión

Esta normativa se revisa anualmente o cuando sea necesario.

Próxima revisión: [Fecha]

10.2 Excepciones

Las excepciones a esta normativa deben ser aprobadas por el CISO y documentadas formalmente, incluyendo la justificación y las medidas compensatorias aplicadas.

11. ACEPTACIÓN

He leído y comprendido la Normativa de Protección del Puesto de Trabajo y me comprometo a cumplirla.

Nombre: _____

Firma: _____

Fecha: _____

ANEXOS

- Anexo A: Checklist de Seguridad del Puesto
- Anexo B: Guía Rápida de Contraseñas Seguras
- Anexo C: Cómo Identificar Phishing

PLANTILLA 3: PLAN ANUAL DE CONCIENCIACIÓN EN CIBERSEGURIDAD

[LOGO EMPRESA]

PLAN ANUAL DE CONCIENCIACIÓN EN CIBERSEGURIDAD

Año: 2025

RESUMEN EJECUTIVO

[Breve descripción del plan, objetivos principales y recursos necesarios]

Este Plan Anual de Concienciación en Ciberseguridad tiene como objetivo elevar el nivel de conocimiento y conciencia de todos los empleados sobre las amenazas cibernéticas y las mejores prácticas de seguridad. El plan contempla actividades mensuales, campañas trimestrales, formación obligatoria y simulaciones de ataques para crear una cultura de seguridad robusta en la organización.

1. ANÁLISIS DE SITUACIÓN

1.1 Contexto Organizacional

Número de empleados: [XXX]

Nivel de madurez en ciberseguridad: [Inicial/Gestionado/Definido/Optimizado]

Presupuesto disponible: [XXX €]

1.2 Incidentes Previos (Últimos 12 meses)

- [X] incidentes de phishing exitosos
- [X] infecciones de malware
- [X] pérdidas de dispositivos
- [X] accesos no autorizados

1.3 Evaluación Actual de Concienciación

[Resultados de encuestas/tests previos]

- **Nivel de conocimiento:** [bajo/medio/alto]
- **Principales brechas:** [Ej: identificación de phishing, gestión de contraseñas...]

2. OBJETIVOS

2.1 Objetivo General

Elevar el nivel de concienciación en ciberseguridad de todos los empleados para reducir incidentes causados por factor humano en un X% durante 2025.

2.2 Objetivos Específicos (SMART)

- 1. Phishing:** Reducir la tasa de clic en simulaciones de phishing del actual 35% a menos del 10% para diciembre 2025.
- 2. Formación:** Lograr que el 95% de empleados complete la formación anual obligatoria antes del 30/11/2025.
- 3. Reporte:** Incrementar el número de reportes de incidentes por empleados del actual 5% al 30% para diciembre 2025.
- 4. Contraseñas:** Reducir el uso de contraseñas débiles del 40% al 10% mediante auditorías trimestrales.

3. PÚBLICO OBJETIVO Y SEGMENTACIÓN

3.1 Segmentos Identificados

Segmento	Nº personas	Características	Necesidades específicas
Alta Dirección	10	Poco tiempo, nivel técnico bajo	Sesiones ejecutivas, riesgos de negocio
Mandos intermedios	30	Responsables de equipos	Gestión de incidentes, liderazgo
Empleados técnicos (IT)	50	Nivel técnico alto	Formación avanzada, herramientas
Empleados administrativos	80	Nivel técnico medio-bajo	Formación práctica, casos cotidianos
Nuevas incorporaciones	~20/año	Sin contexto de empresa	Onboarding de seguridad

4. CONTENIDOS Y MENSAJES CLAVE

4.1 Temas a Abordar (por prioridad)

1. Phishing e Ingeniería Social ■

- Cómo identificar correos sospechosos
- Técnicas de manipulación
- Qué hacer ante la duda

2. Gestión de Contraseñas ■

- Creación de contraseñas fuertes
- Uso de gestor de contraseñas
- Autenticación multifactor

3. Navegación y Descargas Seguras ■

- Identificar sitios web seguros (HTTPS, certificados)
- Evitar descargas maliciosas
- Uso responsable de Internet

4. Protección de Datos Personales ■■

- RGPD en el día a día
- Clasificación de información
- Compartición segura

5. Teletrabajo Seguro ■

- VPN obligatoria
- Seguridad WiFi doméstica
- Videoconferencias seguras

6. Dispositivos Móviles ■

- Bloqueo y cifrado
- Apps autorizadas
- Qué hacer si se pierde

7. Ingeniería Social Física ■

- Tailgating
- Pretexting

- Escritorio limpio

8. Redes Sociales ■

- Qué no compartir
- Privacidad en redes
- Proteger la imagen corporativa

5. METODOLOGÍAS Y ACTIVIDADES

5.1 Formación Inicial (Onboarding)

Qué: Sesión obligatoria para nuevas incorporaciones

Duración: 1 hora

Contenido: Introducción a principios, normativas, amenazas básicas

Frecuencia: En primera semana de incorporación

5.2 Formación Anual Obligatoria

Qué: Curso e-learning completo

Duración: 2 horas

Contenido: Todos los temas (actualizado anualmente)

Metodología: Plataforma LMS con vídeos, tests

Periodo: Septiembre-Noviembre

Evaluación: Test final (80% aciertos mínimo)

5.3 Píldoras Formativas Mensuales

Qué: Microlearning sobre tema específico

Duración: 5-10 minutos

Formato: Vídeo corto, infografía, newsletter

Envío: Primer lunes de cada mes

5.4 Campañas de Sensibilización Trimestrales

Qué: Campaña intensiva de 2 semanas sobre un tema

Formatos: Emails, pósters, salvapantallas, mensajes en TV corporativa

Temas por trimestre: Q1: Phishing | Q2: Contraseñas | Q3: Teletrabajo | Q4: Protección de Datos

5.5 Simulaciones de Phishing

Frecuencia: Mensual

Dificultad: Gradual (empezar fácil, ir aumentando)

Acción post-clic: Página educativa, no punitiva

Seguimiento: Usuarios con >2 clics → formación adicional

5.6 Eventos Presenciales

Hack Day: Evento anual con demos de ataques y defensas

Security Champions: Programa de embajadores de seguridad (voluntarios)

Charlas de expertos: 2 al año (externas)

5.7 Gamificación

Mes de la Ciberseguridad (Octubre): Retos, premios

Quiz mensual: Ranking, premios simbólicos

Escape Room virtual: Anual, por equipos

5.8 Comunicación Continua

Canal de Seguridad en Slack/Teams

Firma de email con tip mensual

Boletín de seguridad trimestral

6. CALENDARIO DE ACTIVIDADES 2025

Resumen por Trimestres:

PRIMER TRIMESTRE (Enero-Marzo):

- Píldoras mensuales sobre resoluciones de seguridad, actualizaciones, RGPD
- Simulaciones de phishing nivel 1-2
- Campaña Q1: PHISHING (2 semanas en Marzo)
- Charla para Alta Dirección sobre riesgos de negocio

SEGUNDO TRIMESTRE (Abril-Junio):

- Píldoras sobre seguridad móviles, ingeniería social física, navegación
- Simulaciones de phishing nivel 2
- Lanzamiento programa Security Champions
- Campaña Q2: CONTRASEÑAS (2 semanas en Junio)
- Auditoría de contraseñas débiles
- Charla de experto externo

TERCER TRIMESTRE (Julio-Septiembre):

- Píldoras sobre seguridad en vacaciones, copias de seguridad, vuelta al trabajo
- Simulaciones de phishing nivel 3
- **FORMACIÓN ANUAL OBLIGATORIA** (Septiembre completo)
- Campaña Q3: TELETRABAJO (2 semanas en Septiembre)

CUARTO TRIMESTRE (Octubre-Diciembre):

- **MES DE LA CIBERSEGURIDAD (Octubre):** Hack Day, Escape Room, múltiples actividades
- Píldora sobre compras online seguras (Black Friday)
- Campaña Q4: PROTECCIÓN DE DATOS (2 semanas en Diciembre)
- Cierre formación anual (recordatorio rezagados)
- Evaluación anual del plan
- Reconocimientos Security Champions

Nota: El calendario mensual detallado con todas las actividades específicas se mantiene en un documento complementario de gestión del proyecto. Este incluye responsables específicos, fechas exactas y dependencias entre actividades.

7. RECURSOS Y PRESUPUESTO

7.1 Recursos Humanos

- CISO / Responsable de Seguridad: 30% dedicación
- Técnico de Seguridad: 20% dedicación
- DPO: 10% dedicación
- Soporte RRHH: 10% dedicación

7.2 Recursos Técnicos

- Plataforma LMS: [nombre]
- Herramienta simulación phishing: [GoPhish/KnowBe4/similares]
- Herramienta gamificación: [Kahoot Pro]
- Software diseño: [Canva Pro]

7.3 Presupuesto Estimado

Concepto	Coste Anual
Plataforma e-learning (LMS)	2.000 €
Herramienta simulación phishing	3.500 €
Creación contenidos (vídeos, infografías)	5.000 €
Eventos presenciales (Hack Day, charlas)	4.000 €
Premios y gamificación	1.500 €
Materiales físicos (pósters, merchandising)	1.000 €
Contingencia (10%)	1.700 €
TOTAL	18.700 €

8. INDICADORES Y MÉTRICAS (KPIs)

8.1 KPIs de Participación

- % empleados que completan formación anual (Objetivo: $\geq 95\%$)
- % asistencia a eventos presenciales (Objetivo: $\geq 70\%$)
- Visualizaciones de píldoras mensuales (Objetivo: $\geq 80\%$)

8.2 KPIs de Conocimiento

- Nota media en test de formación (Objetivo: $\geq 8/10$)
- % empleados que aprueban a la primera (Objetivo: $\geq 85\%$)

8.3 KPIs de Comportamiento

- % clics en simulaciones de phishing (Objetivo: $< 10\%$)
- % reportes de phishing recibidos (Objetivo: $> 30\%$)
- Tiempo medio de reporte de incidentes (Objetivo: $< 2h$)
- % contraseñas débiles en auditorías (Objetivo: $< 10\%$)

8.4 KPIs de Impacto

- N° incidentes causados por factor humano (Objetivo: -50%)
- Coste de incidentes de seguridad (Objetivo: -40%)

8.5 Reporting

- **Mensual:** Dashboard con métricas principales → CISO
- **Trimestral:** Informe detallado → Dirección
- **Anual:** Evaluación completa del plan → Comité de Dirección

9. GESTIÓN DE RIESGOS DEL PLAN

Riesgo	Prob.	Impacto	Mitigación
Baja participación en formación	Media	Alto	Comunicación previa, apoyo de managers, gamificación
Rechazo por "sobrecarga de información"	Media	Medio	Espaciar actividades, contenido atractivo
Falta de apoyo de la Dirección	Baja	Alto	Sesiones para Dirección, vincular a riesgos de negocio
Presupuesto insuficiente	Media	Medio	Priorizar actividades críticas, soluciones económicas
Resistencia al cambio cultural	Alta	Alto	Enfoque positivo no punitivo, celebrar éxitos

10. EVALUACIÓN Y MEJORA CONTINUA

10.1 Evaluación Trimestral

- Revisión de KPIs
- Ajustes en calendario si necesario
- Lecciones aprendidas

10.2 Evaluación Anual

- Cumplimiento de objetivos
- ROI del programa
- Encuesta de satisfacción a empleados
- Propuestas de mejora para siguiente año

10.3 Proceso de Mejora

- Recoger feedback continuo
- Analizar incidentes ocurridos
- Adaptar contenidos a amenazas emergentes
- Incorporar mejores prácticas del sector

ANEXOS

- Anexo A: Contenido detallado de la formación anual
- Anexo B: Ejemplos de píldoras formativas
- Anexo C: Plantillas de emails de phishing para simulaciones
- Anexo D: Modelo de encuesta de evaluación
- Anexo E: Dashboard de KPIs (mockup)

PLANTILLA 4: INFORME DE AUDITORÍA

[LOGO EMPRESA]

INFORME DE AUDITORÍA

Plan de Prevención y Concienciación en Ciberseguridad

INFORMACIÓN DEL INFORME

Organización auditada: [Nombre]

Auditor(es): [Nombres]

Fecha de auditoría: [DD/MM/AAAA - DD/MM/AAAA]

Fecha del informe: [DD/MM/AAAA]

Versión: 1.0

Clasificación: CONFIDENCIAL

RESUMEN EJECUTIVO

[Breve resumen de 1 página máximo con:]

- **Alcance de la auditoría:** Evaluación del Plan de Prevención y Concienciación de [ORGANIZACIÓN] durante el periodo [FECHAS].
- **Principales hallazgos:** Se identificaron X hallazgos críticos, Y altos, Z medios y W bajos. Las áreas de mayor preocupación son [...].
- **Nivel de madurez global:** La organización se encuentra en nivel [X] de madurez en ciberseguridad.
- **Recomendaciones clave:**
 1. [Recomendación crítica 1]
 2. [Recomendación crítica 2]
 3. [Recomendación crítica 3]

Conclusión general: [Verde/Amarillo/Rojo]

Nivel de cumplimiento: [X%]

Nivel de madurez: [Nivel 1-5]

ÍNDICE

- 1. Alcance y Metodología
- 2. Resumen de Hallazgos
- 3. Hallazgos Detallados
- 4. Evaluación del Nivel de Madurez
- 5. Recomendaciones
- 6. Plan de Acción Propuesto
- 7. Anexos

1. ALCANCE Y METODOLOGÍA

1.1 Objetivo de la Auditoría

Evaluar el grado de implementación y efectividad del Plan de Prevención y Concienciación en Ciberseguridad de [ORGANIZACIÓN].

1.2 Alcance

- ✓ Revisión documental de políticas y normativas
- ✓ Evaluación de controles técnicos implementados
- ✓ Evaluación del nivel de concienciación de empleados
- ✓ Análisis de métricas de incidentes
- ✓ Periodo evaluado: [fecha inicio - fecha fin]

1.3 Metodología

- Revisión documental (10 documentos)
- Entrevistas (15 personas)
- Observaciones in situ (5 ubicaciones)
- Simulación de phishing (muestra de 50 empleados)
- Tests de conocimiento (muestra de 30 empleados)
- Análisis técnico (30 equipos auditados)

1.4 Muestra

- Empleados entrevistados: [N] de [Total]
- Ubicaciones visitadas: [N] de [Total]
- Equipos revisados: [N] de [Total]

1.5 Criterios de Evaluación

- Políticas y procedimientos documentados
- ISO/IEC 27001:2022
- Esquema Nacional de Seguridad (ENS)
- RGPD
- Mejores prácticas del sector

2. RESUMEN DE HALLAZGOS

2.1 Distribución por Severidad

Severidad	Cantidad	%
■ CRÍTICO	2	15%
■ ALTO	3	23%
■ MEDIO	5	38%
■ BAJO	3	23%
TOTAL	13	100%

2.2 Hallazgos por Categoría

Categoría	Hallazgos
Documentación	3
Controles Técnicos	4
Concienciación	4
Procesos	2

2.3 Principales Fortalezas

- ✓ Existencia de documentación básica de seguridad
- ✓ Compromiso visible de la Dirección con la ciberseguridad
- ✓ Herramientas técnicas de protección implementadas
- ✓ [Otras fortalezas identificadas]

2.4 Principales Debilidades

- ✗ Falta de actualización de documentación (última revisión hace 2 años)
- ✗ Cobertura insuficiente de formación (solo 65% de empleados formados)
- ✗ Ausencia de métricas consolidadas y dashboard de KPIs
- ✗ [Otras debilidades identificadas]

3. HALLAZGOS DETALLADOS

HALLAZGO #01

Severidad: ■ CRÍTICO

Categoría: Controles Técnicos

Título: Cifrado de disco no implementado en portátiles

Descripción:

Durante la auditoría se identificó que 15 de 30 portátiles (50%) no tienen activado el cifrado de disco completo, incumpliendo la normativa interna.

Evidencia:

- Auditoría técnica realizada el DD/MM/AAAA
- Captura de pantalla: [Anexo A]
- Lista de equipos afectados: [Anexo B]

Riesgo:

En caso de pérdida o robo de un portátil sin cifrar, toda la información contenida (incluyendo datos personales, credenciales guardadas, documentos confidenciales) quedaría expuesta.

Impacto: ALTO - Posible multa RGPD, pérdida de información confidencial

Probabilidad: MEDIA - Pérdida de portátiles ocurre ocasionalmente

Requisitos incumplidos:

- Normativa de Puesto de Trabajo, sección 5.4
- RGPD Art. 32 (medidas de seguridad)
- ENS mp.info.3 (cifrado)

Recomendación:

1. Implementar cifrado (BitLocker/FileVault) en TODOS los portátiles
2. Verificación por IT en plazo máximo 30 días
3. Política de no entrega de portátiles sin cifrado activado
4. Auditoría trimestral automatizada del estado de cifrado

Responsable: Responsable IT

Plazo recomendado: INMEDIATO (30 días)

Nota: Se ha incluido un ejemplo de hallazgo detallado. En el informe completo, cada uno de los 13 hallazgos identificados seguiría este mismo formato estructurado.

4. EVALUACIÓN DEL NIVEL DE MADUREZ

Se ha evaluado el nivel de madurez en ciberseguridad usando un modelo de 5 niveles:

Escala:

- 1. **Inicial:** Ad-hoc, reactivo, sin proceso definido
- 2. **Gestionado:** Procesos básicos, algo documentado
- 3. **Definido:** Procesos estandarizados y documentados
- 4. **Gestionado Cuantitativamente:** Medición y métricas
- 5. **Optimizado:** Mejora continua, proactivo

Evaluación por Área:

Área	Nivel Actual	Nivel Objetivo	Gap
Documentación y Políticas	2.5	4	1.5
Controles Técnicos	3	4	1
Concienciación de Empleados	2	4	2
Gestión de Incidentes	2.5	4	1.5
Métricas y Reporting	1.5	4	2.5
PROMEDIO GLOBAL	2.3	4	1.7

Interpretación:

La organización se encuentra en un nivel **GESTIONADO** (nivel 2), con procesos básicos implementados pero con margen significativo de mejora para alcanzar el nivel **GESTIONADO CUANTITATIVAMENTE** (nivel 4) objetivo.

5. RECOMENDACIONES PRIORITARIAS

5.1 Recomendaciones CRÍTICAS (implementar <30 días)

1. Implementar cifrado completo de disco en todos los portátiles

- Responsable: IT Manager
- Coste estimado: Bajo (funcionalidad nativa)

2. Actualizar Política de Seguridad (última versión de 2021)

- Responsable: CISO
- Coste estimado: Bajo (recursos internos)

5.2 Recomendaciones ALTAS (implementar <90 días)

3. Aumentar cobertura de formación del 65% al 95%

- Responsable: RRHH + CISO
- Coste estimado: Medio

4. Implementar simulaciones de phishing mensuales

- Responsable: Equipo Seguridad
- Coste estimado: 3.000-5.000€/año

5. Establecer dashboard de métricas de seguridad

- Responsable: CISO
- Coste estimado: Bajo-Medio

6. PLAN DE ACCIÓN PROPUESTO

#	Recomendación	Responsable	Plazo	Recursos	Estado
1	Cifrado disco	IT Manager	30 días	40h	Pendiente
2	Actualizar política	CISO	30 días	20h	Pendiente
3	Cobertura formación	RRHH+CISO	90 días	60h + 5K€	Pendiente
4	Simulación phishing	Seg. Team	90 días	30h + 4K€	Pendiente
5	Dashboard métricas	CISO	90 días	80h + 2K€	Pendiente

Inversión total estimada: [XX.XXX €]

Recursos humanos necesarios: [XXX horas]

7. SEGUIMIENTO Y PRÓXIMOS PASOS

7.1 Seguimiento de Recomendaciones

- Reunión de seguimiento mensual
- Revisión del plan de acción
- Actualización de estado de cada recomendación

7.2 Próxima Auditoría

- **Fecha recomendada:** [6-12 meses desde esta auditoría]
- **Enfoque:** Verificar implementación de recomendaciones y evaluar mejoras

ANEXOS

- Anexo A: Checklist de auditoría completo
- Anexo B: Lista de personas entrevistadas
- Anexo C: Evidencias fotográficas
- Anexo D: Capturas de pantalla de controles técnicos
- Anexo E: Resultados detallados de simulación de phishing
- Anexo F: Resultados de tests de conocimiento
- Anexo G: Documentos revisados
- Anexo H: Metodología detallada

FIRMAS

Preparado por:

_____ **Fecha:** _____
[Nombre], Auditor

Revisado por:

_____ **Fecha:** _____
[Nombre], Auditor Senior

Aprobado por:

_____ **Fecha:** _____
[Nombre], CISO

REFERENCIAS Y RECURSOS

6. REFERENCIAS Y RECURSOS

6.1 Normativas y Estándares

ISO/IEC 27001:2022

Sistemas de gestión de la seguridad de la información - Requisitos

<https://www.iso.org/standard/27001>

ISO/IEC 27002:2022

Código de prácticas para los controles de seguridad de la información

<https://www.iso.org/standard/75652.html>

Esquema Nacional de Seguridad (ENS)

Real Decreto 311/2022 (España)

<https://ens.ccn.cni.es/>

RGPD - Reglamento General de Protección de Datos

Reglamento (UE) 2016/679

<https://gdpr.eu/>

NIST Cybersecurity Framework

Framework para mejorar la ciberseguridad de infraestructuras críticas

<https://www.nist.gov/cyberframework>

6.2 Recursos Adicionales

Organismos Oficiales

- **INCIBE - Instituto Nacional de Ciberseguridad**
<https://www.incibe.es>
- **CCN-CERT - Centro Criptológico Nacional**
<https://www.ccn-cert.cni.es>
- **ENISA - Agencia de la Unión Europea para la Ciberseguridad**
<https://www.enisa.europa.eu>

Formación y Concienciación

- **SANS Security Awareness**
<https://www.sans.org/security-awareness-training>
- **KnowBe4 - Plataforma de formación**
<https://www.knowbe4.com>
- **Cybrary - Cursos online gratuitos**
<https://www.cybrary.it>

Herramientas Open Source

- **GoPhish - Simulación de phishing**
<https://getgophish.com>
- **Moodle - Plataforma LMS**
<https://moodle.org>
- **MISP - Plataforma de compartición de amenazas**
<https://www.misp-project.org>

6.3 Sobre este Documento

Autor: Material educativo del CIFP César Manrique

Módulo: Incidentes de Ciberseguridad (991NTA_CIBERTIC)

Curso: Especialización en Ciberseguridad en Entornos de las TI

Año académico: 2024-2025

Versión: 1.0

Última actualización: Octubre 2024

Este documento contiene plantillas de referencia para el desarrollo de las actividades asociadas al RA1 del módulo. Las plantillas deben ser adaptadas a las necesidades específicas de cada organización.